



DPDP COMPLIANCE AUDIT

ai-email-drafter

Digital Personal Data Protection Act 2023



90/100

Grade A — Strong

Scanned: 24 March 2026

Files indexed: 8

Languages: express, dotenv, cors, axios, react, vite

CONFIDENTIAL — Internal Use Only

EXECUTIVE SUMMARY

The application collects recipient email addresses, subjects, and email content for drafting emails. The primary risk is the potential for unauthorized access or misuse of recipient email addresses and the content of emails being drafted.

Validation Summary Rule findings: 5 confirmed, 3 false positives suppressed • AI gaps: 0 dual-validated • Score: 90 (rules) → 90 (integrated)

Severity	Count	Status
MEDIUM	1	Requires Action
INFO	3	Advisory/Info

Tech Stack: express, dotenv, cors, axios, react
Risk Profile: The application collects recipient email addresses, subjects, and email content for drafting emails. The primary risk is the potential for unauthorized access or misuse of recipient email addresses and the content of emails being drafted.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	9.0/18 (50%)	WARN
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	8/8 (100%)	PASS
Section 8(6)	8	6.8/8 (85%)	PASS
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	4/4 (100%)	PASS
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		4/4 (100%)	PASS

Estimated Total Remediation Effort: 1.1–3.9 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Application Logs

PII fields: email

index.js

Flow 2: Application Logs

PII fields: email, address, password

index.js → emailRoutes.js → emailController.js

Flow 3: Application Logs

PII fields: email

DraftEmail.jsx

Flow 4: Application Logs

PII fields: email, address, password

emailRoutes.js → emailController.js

Rule	Section	Severity	File
NO_BREACH_ALERTING	Section 8(6) — Breach	LOW	N/A
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A
NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
NO_CROSS_BORDER_DETECTED	Section 16 — Cross-Border Transfer	INFO	N/A
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	MEDIUM	frontend/src/components/DraftEmail.jsx

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 2 — High Priority (1–3 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Plaintext Pii In Logs — components/DraftEmail.jsx (1–3 hrs)

Week 4 — Advisory (2–6 hours)

Address before next compliance review.

- No Breach Alerting (2–6 hrs)

Total estimated remediation effort: 3–9 hours (0.4–1.1 engineering days)

DETAILED FINDINGS

Finding 1 of 5

[Section 8(6) — Breach]

1. [LOW] NO_BREACH_ALERTING — N / A

Estimated fix time: 2–6 hours

Structured logging detected but no breach notification mechanism found. DPDP Section 8(6) requires notifying affected individuals and the Authority without undue delay when a breach occurs. Logging alone is insufficient — implement automated alerting (Sentry, PagerDuty, or equivalent) with escalation to a compliance team.

Risk:

The codebase lacks any mechanism for automated breach alerting and notification to affected individuals and the Data Protection Authority as required by DPDP Section 8(6). This absence means that in the event of a data breach, timely notification may not occur, leading to non-compliance and potential harm to individuals.

Fix:

1. Integrate an error monitoring and alerting service (e.g., Sentry, Datadog, PagerDuty) into the backend application.
2. Configure the alerting service to monitor for critical errors and security-related events.
3. Establish an escalation policy within the alerting service to notify a designated compliance team or individual upon detection of a potential breach.
4. Implement a process for generating and sending breach notifications to affected individuals and the Data Protection Authority when an alert is confirmed.

DPDP:

Section 8(6) — Breach

Example:

```
// Example using Sentry for error monitoring in backend/index.js import * as Sentry from
 '@sentry/node'; Sentry.init({ dsn: process.env.SENTRY_DSN, environment: process.env.NODE_ENV,
 // Add other Sentry configurations as needed }); // ... rest of your express app setup ... //
 Example of capturing an error try { // ... your code ... } catch (error) {
 Sentry.captureException(error); // ... handle error response ... }
```

Finding 2 of 5

[Section 5 — Notice]

2. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 3 of 5

[Section 5 — Purpose Limitation]

3. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 4 of 5

[Section 16 — Cross-Border Transfer]

4. [INFO] NO_CROSS_BORDER_DETECTED — N / A

No foreign cloud or non-India region config detected.

Finding 5 of 5

[Section 8(1) — Security]

5. [MEDIUM] PLAINTEXT_PII_IN_LOGS — frontend / src / components / DraftEmail.jsx:18

Evidence snippet: console.log('■ Draft Email:', res.data.draft);

Estimated fix time: 1–3 hours

PII keyword appears in logging call. Personal data may be written to logs in plaintext.

Risk:

The rule engine flagged potential PII in logs, but the provided code snippet for `DraftEmail.jsx` does not contain explicit PII keywords within its logging statements. Without further context on what `res.data.draft` contains, it's not confirmed that PII is being logged in plaintext.

Fix:

1. Review the content of `res.data.draft` in the `handleDraft` function to ensure it does not contain PII before logging.
2. If `res.data.draft` can contain PII, implement PII masking or redaction before the `console.log` statement.
3. Consider using a more robust logging library that supports PII detection and redaction.

DPDP:

Section 8(1) — Security

Example:

```
const handleDraft = async () => { try { const res = await
axios.post('http://localhost:5000/api/email/draft', { to, subject, context }); // Example:
Redact PII if present before logging const logData = { ...res.data.draft }; // Shallow copy if
(logData.sensitiveField) { logData.sensitiveField = '[REDACTED]'; } console.log('■ Draft
Email:', logData); setResponse(res.data.draft); } catch (error) { console.error('■ Frontend
Axios error:', error); setResponse('Error generating email draft. Please try again later.')}
};
```